Figure 7.1 GitHub allows users to manually create scoped tokens, which they call personal access tokens. The tokens never expire but can be restricted to only allow access to parts of the GitHub API by setting the scope of the token.

7.1.1 Adding scoped tokens to Natter

Adapting the existing login endpoint to issue scoped tokens is very simple, as shown in listing 7.1. When a login request is received, if it contains a scope parameter then you can associate that scope with the token by storing it in the token attributes. Because it's still useful to allow unscoped tokens for first-party clients, you can leave the scope restriction out if none is specified. Open the TokenController.java file in your editor and update the login method to add support for scoped tokens, as in the following listing.

> **WARNING** There is a potential privilege escalation issue to be aware of in this code. A third-party client that is given a scoped token can call this endpoint to exchange it for an unscoped token or one with more scopes. You'll fix that shortly by adding a new access control rule for the login endpoint to prevent this.

Listing 7.1 Issuing scoped tokens

```
public JSONObject login(Request request, Response response) {
    String subject = request.attribute("subject");
    var expiry = Instant.now().plus(10, ChronoUnit.MINUTES);
```